

SPRINT 2 — TASK BREAKDOWN

Tim Security & Authentication

Tabel Master Task

Task ID	Owner	Issue	Deskripsi Singkat	Status
S2-T01	Arman	ISS-017, ISS-025	Refactor JwtUtil + upgrade jjwt 0.9.1 → 0.11.5 (Keys.hmacSha KeyFor, parserBuilder)	Skip dulu (belum valid)
S2-T02	Dimas	ISS-019	Null-safety di JwtUtil (return Optional)	Belum
S2-T04	Nazriel	PB-12	Tambah feature flag auth.local-validation.enabled (untuk Sprint 3)	Belum
S2-T05	Arman	ISS-017, ISS-NEW-09	Pindah jwt.secret ke env variable + perbaiki expiration	Selesai
S2-T06	Arman	ISS-014	Hapus hardcoded credential panitiad3/panitiad4 di scheduled job	Selesai
S2-T07	Arman	—	.env.example + dokumentasi	Selesai

			env-setup + pre-commit hook gitleaks	
S2-T08	Dimas	ISS-013	Hapus SecurityConte xtLogoutHandl er di awal filter	Selesai
S2-T09	Dimas	ISS-010	Bersihkan logic bypass auth path	Selesai
S2-T10	Dimas	ISS-030	Ganti System.out.pri ntln jadi SLF4J logger	Selesai
S2-T11	Nazriel	ISS-012, ISS-NEW-03	Fix Cookie format + tambah Secure + SameSite=Stric t	Selesai
S2-T12	Nazriel	ISS-013	Hapus SecurityConte xtLogoutHandl er di endpoint /logout	Selesai
S2-T13	Nazriel	—	Hapus setAuthenticati on manual di AccountServic e.login	Selesai

Pembagian Beban Kerja

Anggota	Total Task	Selesai	Sisa
---------	------------	---------	------

Arman	4 (T05, T06, T07, T01)	3	1 (T01 — perlu jjwt upgrade)
Dimas	4 (T08, T09, T10, T02)	3	1 (T02 — null-safety)
Nazriel	4 (T11, T12, T13, T04)	3	1 (T04 — feature flag)
Faiz	Verifikasi & dokumentasi	-	Ongoing

Rincian Task

S2-T01 — Refactor JwtUtil + Upgrade jjwt 0.9.1 → 0.11.5

- **Owner:** Arman
- **Status:** Belum
- **Issue:** ISS-017, ISS-025

Masalah:

JwtUtil.java masih pakai API jjwt 0.9.1 yang sudah deprecated dan tidak menerima security update lagi. Library jjwt versi modern (0.11.x) sudah pakai Keys.hmacShaKeyFor(byte[]) untuk membangun Key object. Secret string "token" (5 karakter) terlalu lemah untuk HS512 yang butuh minimal 64 byte (512 bit).

Solusi:

Step 1 — Update pom.xml:

```
<!-- HAPUS yang lama: -->
<dependency>
  <groupId>io.jsonwebtoken</groupId>
  <artifactId>jjwt</artifactId>
  <version>0.9.1</version>
</dependency>

<!-- TAMBAHKAN tiga dependency baru (jjwt 0.11.x split jadi modular): -->
<dependency>
  <groupId>io.jsonwebtoken</groupId>
  <artifactId>jjwt-api</artifactId>
  <version>0.11.5</version>
</dependency>
<dependency>
```

```

    <groupId>io.jsonwebtoken</groupId>
    <artifactId>jjwt-impl</artifactId>
    <version>0.11.5</version>
    <scope>runtime</scope>
</dependency>
<dependency>
    <groupId>io.jsonwebtoken</groupId>
    <artifactId>jjwt-jackson</artifactId>
    <version>0.11.5</version>
    <scope>runtime</scope>
</dependency>

```

Step 2 — Update JwtUtil.java:

```

import io.jsonwebtoken.security.Keys;
import javax.crypto.SecretKey;
import java.nio.charset.StandardCharsets;

```

```

@Value("${jwt.secret}")
private String tokenSecret;
private SecretKey signingKey;

```

```

@PostConstruct
void initSigningKey() {
    byte[] keyBytes = tokenSecret.getBytes(StandardCharsets.UTF_8);
    if (keyBytes.length < 64) {
        throw new IllegalStateException("JWT_SECRET terlalu pendek untuk HS512. Butuh minimal
64 byte.");
    }
    this.signingKey = Keys.hmacShaKeyFor(keyBytes);
}

```

```

// Update semua tempat parsing:
public boolean validateToken(String authToken) {
    if (authToken == null) return false;
    try {
        Jwts.parserBuilder() // ← API baru
            .setSigningKey(signingKey)
            .build()
            .parseClaimsJws(authToken);
        return true;
    } catch (JwtException ex) {

```

```

        throw new BadCredentialsException("INVALID_CREDENTIALS", ex);
    }
}

```

Acceptance Criteria:

- [] pom.xml tidak ada lagi artifactId jjwt (yang 0.9.1).
- [] pom.xml ada jjwt-api, jjwt-impl, jjwt-jackson versi 0.11.5.
- [] mvn compile tidak ada warning deprecated.
- [] Semua Jwts.parser().setSigningKey(...) sudah diganti
Jwts.parserBuilder().setSigningKey(signingKey).build().
- [] Aplikasi tetap bisa generate token, parse token, dan validasi signature.
- [] Aplikasi gagal start kalau secret < 64 byte (fail fast).

S2-T02 — Null-Safety di JwtUtil

- **Owner:** Dimas
- **Status:** Belum
- **Issue:** ISS-019

Masalah:

Kalau token bisa di-parse tapi sub-nya bukan integer, Integer.parseInt(id) melempar exception. Kalau account tidak ada di DB, me-return null. Filter caller tidak melakukan null-check, sehingga lanjut ke loadUserByUsername(null) yang akan membuat service crash.

Solusi:

Ubah signature method menjadi Optional<String> dan update caller di CustomJwtAuthenticationFilter.

```

public Optional<String> getUsernameFromToken(String token) {
    if (token == null || token.isBlank()) {
        return Optional.empty();
    }
    try {
        Claims claims = Jwts.parserBuilder()
            .setSigningKey(signingKey)
            .build()
            .parseClaimsJws(token)
            .getBody();
        String id = claims.getSubject();
        if (id == null) return Optional.empty();
        return accountRepository.findById(Integer.parseInt(id))
    }
}

```

```

        .map(Account::getUsername);
    } catch (NumberFormatException | JwtException e) {
        log.warn("Invalid token format: {}", e.getMessage());
        return Optional.empty();
    }
}

```

Acceptance Criteria:

- [] Signature method getUsernameFromToken jadi Optional<String>.
- [] Caller di CustomJwtAuthenticationFilter pakai .ifPresent(...), tidak ada panggilan loadUserByUsername(null).
- [] Tidak ada NPE walau token diberi nilai malformed.
- [] Log warning muncul saat token invalid.

S2-T04 — Tambah Feature Flag auth.local-validation.enabled

- **Owner:** Nazriel
- **Status:** Belum
- **Issue:** PB-12 (persiapan Sprint 3)

Masalah:

Di Sprint 3 nanti tim akan migrasi 5 service downstream menjadi validasi JWT lokal. Untuk safety rollback, butuh sakelar (toggle) yang bisa dimatikan tanpa redeploy.

Solusi:

Tambah property di application.properties:

```
auth.local-validation.enabled=${AUTH_LOCAL_VALIDATION_ENABLED:false}
```

Buat class AuthFeatureFlags:

```

@Component
public class AuthFeatureFlags {
    @Value("${auth.local-validation.enabled:false}")
    private boolean localValidationEnabled;

    public boolean isLocalValidationEnabled() {
        return localValidationEnabled;
    }
}

```

Acceptance Criteria:

- [] Property auth.local-validation.enabled ada di config.
- [] Default value false.
- [] Bisa di-override via env variable.

S2-T05 — Pindah jwt.secret ke Environment Variable

- **Owner:** Arman
- **Status:** Selesai
- **Issue:** ISS-017, ISS-NEW-09

Solusi (Diimplementasi):

Memindahkan hardcoded secret ke environment variable dan memperbaiki logic expiration (15 menit untuk access, 7 hari untuk refresh). Ditambah validasi fail-fast saat startup.

Acceptance Criteria:

- [x] Secret tidak ada lagi di source code.
- [x] Aplikasi gagal start dengan pesan jelas kalau JWT_SECRET tidak diset.
- [x] Access token expire 15 menit (default).
- [x] Refresh token expire 7 hari (default).

S2-T06 — Hapus Hardcoded Credential panitiad3/panitiad4

- **Owner:** Arman
- **Status:** Selesai
- **Issue:** ISS-014

Solusi (Diimplementasi):

Credential dipindah ke env variable SCHEDULED_JOB_D3_USERNAME/PASSWORD. Kalau env tidak diset, job melakukan log error dan skip (tidak crash).

Acceptance Criteria:

- [x] Tidak ada string credential di source code.
- [x] Job tetap bisa dijalankan saat scheduler aktif.
- [x] Kalau env tidak diset, job log error dan skip.

S2-T07 — .env.example + Dokumentasi + pre-commit hook

- **Owner:** Arman
- **Status:** Sebagian (gitleaks belum)

Yang Sudah Selesai:

- [x] .env.example ada.

- [x] Dokumentasi docs/security/env-setup.md ada.

S2-T08 — Hapus SecurityContextLogoutHandler di Filter

- **Owner:** Dimas
- **Status:** Selesai
- **Issue:** ISS-013

Masalah:

Pemanggilan redundan di doFilterInternal. Spring Security otomatis membersihkan context.

Acceptance Criteria:

- [x] Tidak ada SecurityContextLogoutHandler di CustomJwtAuthenticationFilter.
- [x] Login flow tidak terganggu.

S2-T09 — Bersihkan Logic Bypass Auth Path

- **Owner:** Dimas
- **Status:** Selesai
- **Issue:** ISS-010

Masalah:

Hardcoded path check di filter.

Solusi (Diimplementasi):

Filter pakai pendekatan graceful: kalau token kosong, lanjut filter chain. SecurityConfig.permitAll() yang menentukan endpoint publik.

Acceptance Criteria:

- [x] Tidak ada hardcoded path check di doFilterInternal.
- [x] Endpoint publik tetap bisa diakses tanpa token.

S2-T10 — Ganti System.out.println jadi SLF4J Logger

- **Owner:** Dimas
- **Status:** Selesai
- **Issue:** ISS-030

Acceptance Criteria:

- [x] Tidak ada System.out.println di paket security.
- [x] Filter pakai @Slf4j Lombok + log.warn(...).

S2-T11 — Fix Cookie Format + Tambah Secure & SameSite=Strict

- **Owner:** Nazriel
- **Status:** Selesai

- **Issue:** ISS-012, ISS-NEW-03

Acceptance Criteria:

- [x] Cookie ber-attribute HttpOnly, Path, SameSite=Strict.
- [x] Komentar untuk .secure(true) saat production.

S2-T12 — Hapus SecurityContextLogoutHandler di Endpoint /logout

- **Owner:** Nazriel
- **Status:** Selesai
- **Issue:** ISS-013

Acceptance Criteria:

- [x] Tidak ada pemanggilan invalidasi session stateful.
- [x] AccountController.logout cuma memanggil SecurityContextHolder.clearContext() + hapus cookie.

S2-T13 — Hapus setAuthentication Manual di AccountService.login

- **Owner:** Nazriel
- **Status:** Selesai

Acceptance Criteria:

- [x] Tidak ada SecurityContextHolder.getContext().setAuthentication(...) di method login.
- [x] Login mengembalikan token dengan status 200.

Status Final Sprint 2

Kategori	Jumlah	Persentase
Selesai (verified)	9 task	75%
Belum (perlu dikerjakan)	3 task	25%
Total	12 task	100%

Sisa Pekerjaan Sebelum Sprint 2 Closure:

1. **Arman** — Selesaikan S2-T01 (jjwt 0.11 upgrade).
2. **Dimas** — Selesaikan S2-T02 (null-safety dengan Optional<String>).
3. **Nazriel** — Selesaikan S2-T04 (feature flag).